INFORME TÉCNICO · TRABAJO DE TITULACIÓN

# Auditoría de Ciberseguridad – GlucoLume

Auditoría técnica incremental basada en riesgos
OWASP Top 10 (2021) · ISO/IEC 27001:2022 · NIST CSF 2.0

| | |
|---|---|
| **Fecha del informe** | 19 de octubre de 2026 |
| **Sistema auditado** | GlucoLume: plataforma experimental de adquisición y análisis de señales ópticas (FastAPI, React, SQL Server, Docker, Nginx, Arduino y puente serie USB/Bluetooth) |
| **Contexto** | Trabajo de titulación · Licenciatura en Sistemas de Información |
| **Código de referencia** | Carpeta C:\Users\VictoriaVMC\Desktop\GlucoLume (única fuente utilizada). Sin repositorio Git. |
| **Línea base** | No disponible dentro de la carpeta (ver sección 8) |
| **Tipo de revisión** | Análisis estático y pruebas dirigidas; sin modificar código, configuración, secretos, Docker ni bases de datos |

**DICTAMEN: CONDICIONADO PARA DESPLIEGUE**

# Índice


| | | |
|---|---|---|
| **1.** | **Conclusión ejecutiva** | **3** |
| **2.** | **Alcance** | **4** |
| **3.** | **Metodología y convenciones** | **5** |
| **4.** | **Arquitectura del sistema** | **6** |
| **5.** | **Controles existentes** | **7** |
| **6.** | **Hallazgos** | **9** |
| 6.1 | Resumen de hallazgos | 9 |
| 6.2 | Registro de accesos y script 034 | 9 |
| 6.3 | Detalle de cada hallazgo | 11 |
| **7.** | **Matriz de riesgos** | **19** |
| **8.** | **Comparación con la auditoría anterior** | **20** |
| **9.** | **Recomendaciones priorizadas** | **21** |
| **10.** | **Pruebas realizadas, no ejecutadas y limitaciones** | **22** |
| **11.** | **Seguridad del software frente a validación clínica del dispositivo** | **24** |
| **12.** | **Dictamen** | **25** |


Este informe evalúa la seguridad del software. No constituye una validación clínica del dispositivo de medición (sección 11).

# 1. Conclusión ejecutiva

GlucoLume presenta, para un proyecto académico, una arquitectura de seguridad deliberada: contraseñas con Argon2id, JWT con algoritmo fijado por configuración y sesiones revocables con rotación y detección de reutilización, MFA TOTP con contador atómico de intentos, autorización centralizada en el servidor, aislamiento por institución, consultas parametrizadas, ausencia de usos peligrosos de HTML en el frontend, contenedores sin privilegios y sin puertos publicados hacia la base. La búsqueda dirigida no encontró inyección SQL, XSS ni patrones de claves en el código fuente, y 317 de 321 pruebas dirigidas pasaron.

La revisión identificó **21 hallazgos: 1 de severidad Alta, 7 Media y 13 Baja**. 6 son vulnerabilidades o defectos confirmados, 6 son riesgos pendientes de validación y 9 son mejoras preventivas.

> **Hallazgo principal (GL-01, Alta).** El interruptor transitorio ALLOW_INDIVIDUAL_ON_INSTITUTIONAL_DEVICE está en `true` en el .env actual y no existe una salvaguarda que impida arrancar en producción con ese valor. Con él activo, una cuenta individual sin relación con la institución pasa los controles de autoridad sobre un dispositivo institucional: tres pruebas de regresión fallan con el .env real y pasan con el interruptor en `false`. Es una regresión de configuración, no de lógica: el código de autorización correcto existe, pero el interruptor lo anula.

> **Registro de accesos y script 034.** El script 034 no está en la carpeta y no pudo revisarse. El esquema de referencia v5 (generado el 19/10/2026) ya contiene la columna `tipoCuentaActor`, lo que contradice el estado «no aplicado»: el estado real de la base queda sin determinar (GL-05). Además, el código que acompaña a 034 emite un `UPDATE` sobre la tabla de auditoría en cada inicio de sesión (confirmado con una prueba de concepto), incompatible con la inmutabilidad que se busca (GL-02, GL-03).

**Dictamen: CONDICIONADO.** El sistema es apto para demostración académica en un entorno controlado, con datos sintéticos y el interruptor GL-01 desactivado. Para operar con datos reales de personas deben cerrarse previamente los puntos P0 y P1 de la sección 9. La carpeta auditada no contiene la auditoría previa ni la documentación referenciada por su README, por lo que no fue posible comparar el estado de hallazgos anteriores (sección 8). Este informe evalúa la seguridad del software; no valida clínicamente el dispositivo (sección 11).

# 2. Alcance

## 2.1 Código de referencia

Por indicación expresa del encargo, la auditoría se limitó a la carpeta `C:\Users\VictoriaVMC\Desktop\GlucoLume` (749 archivos sin contar dependencias): backend FastAPI, frontend React, esquema de referencia de la base, configuración Docker/Nginx/Caddy, firmware y puente de adquisición. No se utilizó ninguna otra carpeta como evidencia ni referencia. La carpeta no contiene repositorio Git, directorio `docs/` ni `database/scripts/`.

## 2.2 Dentro del alcance

- Autenticación, JWT, MFA, OAuth (Google), sesiones y bloqueo de cuentas.
- Autorización, aislamiento institucional, roles de plataforma y acceso a datos de pacientes.
- Inyección SQL, XSS, validación de entradas, secretos y dependencias.
- Configuración Docker, Nginx, Caddy, HTTPS y cabeceras.
- Auditoría y privacidad: registro de accesos, clasificación por tipo de cuenta, retención y minimización.
- Canal del puente de adquisición y su autenticación.
- Esquema SQL de referencia, permisos de SQL Server y respaldos (en la medida en que consta en la carpeta).

## 2.3 Fuera del alcance

- Validez clínica y exactitud de las mediciones del dispositivo (sección 11).
- Pruebas contra sistemas externos (Google, SMTP real), ataques activos, pruebas de carga o de denegación de servicio.
- La base de datos real, el servidor de producción y la consola de Google Cloud: no se inspeccionaron.

# 3. Metodología y convenciones

Auditoría basada en riesgos, con análisis estático dirigido (fragmentos de funciones, no archivos completos), pruebas dirigidas sobre los riesgos identificados y contraste con tres marcos: OWASP Top 10 (2021), ISO/IEC 27001:2022 (Anexo A) y NIST CSF 2.0. Se privilegiaron los cambios recientes, el módulo de auditoría y los controles que protegen datos de salud.

## 3.1 Tipos de hallazgo

| Tipo | Significado |
|---|---|
| Vulnerabilidad confirmada | Se comprobó con una prueba ejecutada, una prueba de concepto o evidencia directa verificable en esta revisión. |
| Riesgo pendiente de validación | El riesgo es plausible pero depende de algo que esta auditoría no pudo ver ni ejecutar (base real, infraestructura, escáner externo). |
| Mejora preventiva | No es una falla actual explotable; es un refuerzo recomendado de defensa en profundidad. |

## 3.2 Severidad

Se combina impacto y probabilidad: **Alta** = impacto alto con probabilidad media o alta; **Media** = impacto alto con probabilidad baja, o impacto medio con probabilidad media o alta; **Baja** = el resto. La matriz de la sección 7 aplica esta regla de forma automática a todos los hallazgos.

## 3.3 Etiquetas de verificación

**[PRUEBA]** ejecutada en esta revisión · **[CÓDIGO]** código o configuración leído en esta revisión, sin ejecutar · **[DOC]** afirmación de un comentario o documento del proyecto, no contrastada · **[NO VERIF.]** depende de un sistema que no se inspeccionó. Los controles no comprobados no se presentan como verificados.

# 4. Arquitectura del sistema




Figura 1. Componentes y límites de confianza según compose.yaml, compose.prod.yaml, docker/nginx/default.conf.template y los servicios del backend. Ningún contenedor de esta carpeta estaba en ejecución durante la revisión: la arquitectura se describe por configuración [CÓDIGO].

## 4.1 Decisiones relevantes para la seguridad

- Autenticación por Bearer, sin cookies de sesión de API (CORS con allow_credentials=False): backend/app/main.py:81-91. La única cookie es la firmada del flujo OAuth (SameSite=Lax, Secure en producción): main.py:70-79.
- Toda autorización se decide en el backend: `requireMembership` (services/institution.py:263), `platformAccess/platformSecure` (api/v1/platform.py:53-68) y `requireAdministrator/requireOwner` en la consulta de auditoría (services/auditQuery.py:101-106).
- Una única cuenta de base de datos con pool de conexiones; sin Row-Level Security nativo.
- Estado compartido en memoria del proceso (límites por IP, monitor de ráfagas, registro de streams): la arquitectura asume una sola réplica.
- El puente serie se autentica con un único token compartido y recibe órdenes por el latido, no por un puerto de escucha.

## 5. Controles existentes

Estado de los controles principales y qué se comprobó en esta revisión.

| Control | Evidencia | Verificación | Marco |
|---|---|---|---|
| Hash de contraseñas | Argon2id; hash ficticio para igualar tiempos (core/security.py:42,132-146); política y lista de contraseñas comunes (:59-130). | [CÓDIGO] | A07 · A.8.5 · PR.AA |
| JWT | Algoritmo fijado por configuración (nunca el del token), iss/aud/exp/iat/sub/typ obligatorios, secreto ≥ 32 caracteres (core/security.py:169-182; core/config.py:122-140). El sid se valida contra la sesión en base y el usuario activo (services/auth.py:1055-1072). | [CÓDIGO] + [PRUEBA] test_security_hardening | A02 · A07 · A.8.24 |
| Sesiones y refresh | Rotación con UPDATE condicionado; reutilizar un refresh revoca todas las sesiones y audita REFRESH_REUTILIZADO (services/auth.py:913-930). | [CÓDIGO] | A07 · A.8.5 |
| MFA TOTP | Secretos cifrados con Fernet; contador de intentos como un único UPDATE condicionado (services/mfa.py:118-132); MFA obligatorio para cuentas de plataforma (api/deps.py:64-72). | [PRUEBA] test_mfa_attempts_atomic | A07 · A.8.5 |
| Bloqueo y límites por IP | Bloqueo por cuenta (services/auth.py:433-473); 14 grupos de endpoints con 429 y Retry-After (api/rateLimit.py:23-38); Nginx limit_req en /api/v1/auth/ (default.conf.template:33,85-87). | [PRUEBA] test_rate_limiter, test_login_lockout; Nginx [CÓDIGO] | A07 · A.8.5 · PR.AA |
| OAuth Google | state, nonce y PKCE en cookie firmada y temporal (api/v1/auth.py); origen restringido; Secure en producción (main.py:70-79). | [CÓDIGO] (sin prueba contra Google) | A07 · A.8.5 |
| Autorización e aislamiento institucional | Control centralizado; datos de salud solo para el operador responsable vigente; reasignación como propuesta aceptada por el destino; auditoría del propietario sin identificar al paciente. | [PRUEBA] test_patient_access, test_manager_reassignment, test_dashboard_privacy, test_device_resolve_authority | A01 · A.5.15 · A.8.3 · PR.AA-05 |
| Autoridad sobre el puente | Solo operadores activos de la institución dueña del dispositivo, con rechazo auditado (services/telemetry.py:124-164). **Degradado por GL-01.** | [PRUEBA] 3 fallos con el .env real | A01 · A.8.3 |
| Inyección SQL | SQLAlchemy Core/ORM parametrizado; sin SQL construido con f-strings; los pocos text() reciben consultas constantes con parámetros (services/schemaCompat.py:19-28). | [CÓDIGO] búsqueda dirigida: 0 coincidencias | A03 · A.8.28 |
| XSS / HTML | Sin dangerouslySetInnerHTML, innerHTML, eval, document.write ni insertAdjacentHTML en frontend/src; autoescape de Jinja2 en correos (emails/renderer.py:34-36); CSP script-src 'self'. | [CÓDIGO] búsqueda dirigida: 0 coincidencias | A03 · A.8.28 |
| Auditoría | Única vía registerEvent; filtrado de claves sensibles (services/audit.py:70-85); identificadores de cuentas inexistentes solo como HMAC (:200-205); consulta restringida a administrador/propietario (auditQuery.py:101-106, 989-1014); contexto (IP, cliente) en tabla aparte con anulación a 90 días (auditRetention.py:6). | [PRUEBA] test_audit_security, test_audit_names, test_audit_minimized_names, test_retention_anonymization | A09 · A.8.15 · DE.CM |
| Cabeceras, HTTPS | Nginx: nosniff, X-Frame-Options DENY, Referrer-Policy, Permissions-Policy, CSP, HSTS condicionado (default.conf.template:41-50); middleware de cabeceras con HSTS en producción (main.py:94); Swagger/OpenAPI deshabilitados en producción (main.py:54-56); Caddy con HSTS. | [PRUEBA] test_security_hardening; Nginx y Caddy [CÓDIGO] | A05 · A.8.20 · PR.PS |
| Contenedores | Usuario sin privilegios (backend/Dockerfile:55; frontend/Dockerfile:47), cap_drop ALL y no-new-privileges (compose.yaml:29-31), sistema de archivos de solo lectura (:51,95,147), red «data» aislada y base sin puertos (:190). SQL Server sin cap_drop (justificado en :177). | [CÓDIGO] (no ejecutado) | A05 · A.8.9 |

| | | | |
|---|---|---|---|
| Secretos | .env, docker/db.env y bridge.env excluidos por .gitignore; .env.example sin valores; sin patrones de claves en el código. JWT_SECRET y SESSION_SECRET de 86 caracteres; BRIDGE_TOKEN de 64. | [CÓDIGO] (nombres y longitudes, no valores) | A02 · A.8.24 |
| Dependencias | Instalación con --require-hashes (backend/Dockerfile:21); package-lock.json y npm ci en el frontend. | [CÓDIGO]; escáneres no ejecutados (GL-13) | A06 · A.8.8 |
| Streams SSE | Tope por cuenta y totales, sesión de base cerrada y revalidación periódica. | [PRUEBA] test_stream_limits | A04 · A.8.6 |
| Recuperación de administración | CLI local (cli/recoverAdmin.py) sin ruta HTTP; todo queda auditado. | [PRUEBA] test_platform_recovery | A07 · A.8.2 |
| Resultados por correo | El correo no se conserva en el registro de envío; la auditoría no registra correos; límite de 3 envíos por medición y hora (measurement.py:995). | [PRUEBA] test_result_email*, test_patient_result_email; riesgos residuales en GL-04 y GL-08 | A04 · A.5.34 |

# 6. Hallazgos

## 6.1 Resumen de hallazgos

| Severidad | Cantidad | Confirmadas (C) | Pendientes de validación (R) | Preventivas (M) |
|---|---|---|---|---|
| Alta | 1 | 1 | 0 | 0 |
| Media | 7 | 3 | 4 | 0 |
| Baja | 13 | 2 | 2 | 9 |
| **Total** | **21** | **6** | **6** | **9** |

| ID | Hallazgo | Tipo | Severidad | Estado |
|---|---|---|---|---|
| GL-01 | Un interruptor de configuración anula la autoridad sobre los dispositivos institucionales y el .env actual lo tiene activo | C | Alta | Abierto |
| GL-02 | El registro del tipo de cuenta (034) emite un UPDATE sobre la tabla de auditoría en cada inicio de sesión | C | Media | Abierto |
| GL-03 | La cuenta de la aplicación tiene permisos amplios y puede modificar o borrar la auditoría | C | Media | Abierto |
| GL-04 | El envío de correo usa STARTTLS sin verificar el certificado del servidor SMTP | C | Media | Abierto |
| GL-05 | El script 034 no está en la carpeta, pero el esquema v5 ya contiene su columna: estado real de la base sin determinar | R | Media | Abierto |
| GL-06 | MFA_ENCRYPTION_KEY está definida dos veces con valores distintos | R | Media | Abierto |
| GL-07 | Cifrado en reposo, TLS verificado hacia la base y respaldos: sin evidencia en la carpeta | R | Media | Abierto |
| GL-08 | Resultados de salud por correo: consentimiento autodeclarado y correo del paciente guardado en claro | R | Media | Abierto |
| GL-09 | La carpeta es incompleta y no reproducible: faltan documentación, scripts SQL y control de versiones | C | Baja | Abierto |
| GL-10 | DATABASE_URL huérfano en el .env duplica la contraseña de la base | C | Baja | Abierto |
| GL-11 | Endpoints del puente sin límite por IP y token único compartido sin rotación | M | Baja | Abierto |
| GL-12 | La suite de pruebas depende del .env real | M | Baja | Abierto |
| GL-13 | Dependencias e imágenes sin reescaneo en esta revisión; imágenes fijadas por etiqueta | R | Baja | Abierto |
| GL-14 | Refresh token en localStorage con «Recordarme» | R | Baja | Riesgo aceptado |
| GL-15 | Contadores y límites en memoria del proceso, sin CAPTCHA y con señales pasivas | M | Baja | Abierto |
| GL-16 | La auditoría se conserva sin límite por defecto | M | Baja | Abierto |
| GL-17 | Clave de cifrado MFA única sin rotación; JWT_SECRET reutilizado como clave de HMAC | M | Baja | Abierto |
| GL-18 | Endurecimientos menores de configuración Docker | M | Baja | Abierto |
| GL-19 | CSP con style-src 'unsafe-inline' | M | Baja | Abierto |
| GL-20 | Secretos reales en texto plano en una carpeta sin repositorio | M | Baja | Abierto |
| GL-21 | BorrarRap.sql (borrado masivo) convive con el esquema de referencia sin controles de entorno | M | Baja | Abierto |

Tipo: C = vulnerabilidad confirmada · R = riesgo pendiente de validación · M = mejora preventiva.

## 6.2 Registro de accesos y script 034

**Qué hace el diseño.** El tablero de la plataforma agrupa los intentos de autenticación en individuales, institucionales, de plataforma y «sin clasificar» (services/authAccess.py). Hoy infiere el tipo desde `Usuario.tipoCuenta` vigente. El script 034 agregaría `Auditoria.tipoCuentaActor` (NVARCHAR(40) NULL, con CHECK de cuatro valores) para que los eventos LOGIN nuevos guarden su propia evidencia; los anteriores quedarían en NULL y se seguirían infiriendo.

| Aspecto | Resultado |
|---|---|
| Contenido del script | [NO VERIF.] El archivo `database/scripts/034_auditoria_tipo_cuenta_actor.sql` no existe en la carpeta, de modo que no se revisaron su idempotencia, su encabezado ni su reversión. Lo que se sabe de él proviene del modelo (backend/app/models/audit.py:34-39,45-49), de schemaCompat y de la prueba que lo lee (test_auth_access_account_type.py:163), que **falla** con FileNotFoundError. |
| Estado «no aplicado» | [CÓDIGO] Contradicho por el esquema v5 (GlucoLume_DB_v5.sql:3,32,1316-1318), que incluye la columna y el CHECK. Base real: [NO VERIF.]. Ver GL-05. |
| Compatibilidad con la base sin migrar | [PRUEBA] El backend no nombra la columna hasta que existe (schemaCompat.auditAccountTypeReady; mapper con exclude_properties); las pruebas que capturan el SQL emitido con y sin columna pasan. Nota: con SQLite la función devuelve siempre verdadero (schemaCompat.py:20-21), por lo que la ruta «sin columna» solo se ejercita simulándola, y en SQL Server no se ejecutó. |
| Exactitud de la clasificación | [PRUEBA] El tipo registrado manda sobre el inferido; un tipo que contradice la institución anotada en el mismo evento se envía a «sin clasificar» en lugar de asignarse; individual + institucional + plataforma + sin clasificar = total. Todas las pruebas de test_auth_access_account_type pasan salvo la del script ausente. |
| Integridad de la escritura | [PRUEBA] Defecto confirmado: el valor se escribe con un UPDATE posterior al INSERT (GL-02), incompatible con un DENY UPDATE/DELETE (GL-03). |
| Autorización del tablero y privacidad | [CÓDIGO] Los accesos por tipo forman parte de la sección de seguridad cuyo alcance «ADMINISTRADOR» solo recibe el administrador (services/platformDashboard.py:159,175); la auditoría detallada exige requireAdministrator/requireOwner (auditQuery.py:989-1014). La IP y el cliente viven en AuditoriaContexto (v5:44-50) y se anulan a los 90 días [CÓDIGO + PRUEBA test_retention_anonymization]. El tipo de cuenta no es un dato sensible adicional. |
| Fidelidad histórica | [CÓDIGO] Los eventos anteriores se infieren del tipo vigente; el propio módulo documenta que solo cambian de tipo los relevos administrador↔moderador (ambos «plataforma»), por lo que la inferencia es estable hoy, pero no hay historial de tipos. El CHECK de cuatro valores está duplicado en modelo y esquema: si se agrega un tipo de cuenta, ambos deben actualizarse. |
| Validación en SQL Server | [NO VERIF.] No hay copia descartable disponible (solo existe la base GlucoLume en la instancia local) y el encargo prohíbe aplicar migraciones o consultar la base real; no se ensayó ningún script. |

## 6.3 Detalle de cada hallazgo

GL-01 **Alta** Vulnerabilidad confirmada — Abierto

### Un interruptor de configuración anula la autoridad sobre los dispositivos institucionales y el .env actual lo tiene activo

| | |
|---|---|
| **Descripción** | ALLOW_INDIVIDUAL_ON_INSTITUTIONAL_DEVICE (pensado como transitorio para un equipo compartido) hace que una cuenta individual se trate como contexto «PERSONAL» permitido sobre un dispositivo asignado a una institución, tanto para dar órdenes al puente serie como para medir con él. El valor por defecto es false, pero el .env actual lo define en true y no existe ninguna salvaguarda que impida arrancar en producción con ese valor (compose.prod.yaml solo fuerza API_ENV). |
| **Evidencia** | `backend/app/services/telemetry.py:153 · backend/app/services/device.py:815-816 · backend/app/core/config.py:88 · .env:13 (valor true) · compose.prod.yaml:8,18,29 (solo API_ENV). Prueba [PRUEBA]: con el .env real fallan 3 pruebas de regresión (test_bridge_command_authority::test_una_cuenta_ajena_no_puede_ordenar_al_puente_de_una_institucion, test_device_context_authority::test_individual_frente_a_un_dispositivo_…_bloqueado, test_telemetry::test_un_dispositivo_de_otra_institucion_no_se_puede_usar); las tres pasan al ejecutar el proceso de prueba con la variable en false.` |
| **Impacto** | **Alto.** Una cuenta sin relación con la institución puede detener, pausar, reconfigurar o reiniciar el puente que atiende un dispositivo institucional y medir con él: afecta la integridad y la disponibilidad de la adquisición de otra organización. No se observó lectura de datos de salud ajenos. |
| **Probabilidad** | **Media.** Plausible: la configuración local ya lo tiene activo y el despliegue lee el .env por env_file. |
| **Severidad** | **Alta** (impacto alto × probabilidad media) · Marcos: A01 · A.5.15 / A.8.3 · PR.AA-05 |
| **Recomendación** | (1) Poner la variable en false en el .env y fijarla a false en compose.prod.yaml. (2) Hacer que Settings rechace el arranque con API_ENV=production si está activa. (3) Si se necesita un equipo compartido, modelarlo como dispositivo de un pool compartido y no como interruptor global. (4) Conservar las tres pruebas y añadir una que verifique el rechazo del arranque. |

GL-02 **Media** Vulnerabilidad confirmada — Abierto

### El registro del tipo de cuenta (034) emite un UPDATE sobre la tabla de auditoría en cada inicio de sesión

| | |
|---|---|
| **Descripción** | Como la columna tipoCuentaActor no se mapea en el ORM, su valor se escribe con un UPDATE posterior al INSERT mediante un listener after_insert, en cada evento LOGIN de una cuenta identificable. Esto contradice el principio de auditoría de solo-inserción y es incompatible con el DENY UPDATE, DELETE que sería deseable sobre Auditoria (GL-03): con ese DENY, el inicio de sesión podría fallar dentro de su transacción. |
| **Evidencia** | `backend/app/models/audit.py:85-91 · backend/app/services/audit.py:277-281. Prueba de concepto [PRUEBA] (SQLite temporal, captura de SQL, script en el directorio temporal de la sesión): un loginLocal exitoso emitió «UPDATE dbo."Auditoria" SET "tipoCuentaActor"=? WHERE dbo."Auditoria"."idAuditoria" = ?».` |
| **Impacto** | **Medio.** Se bloquea el endurecimiento de la auditoría (GL-03) y, al combinarse con él, el inicio de sesión podría devolver errores 500 (no probado contra SQL Server). La evidencia «tipo de cuenta al momento del evento» queda en una fila que la aplicación puede reescribir. |
| **Probabilidad** | **Media.** Ocurre en cada inicio de sesión una vez que la columna existe (ver GL-05); el conflicto aparece cuando se aplique el DENY. |
| **Severidad** | **Media** (impacto medio × probabilidad media) · Marcos: A09 · A04 · A.8.15 · PR.DS-01 |
| **Recomendación** | Escribir tipoCuentaActor en el propio INSERT (INSERT de Core con la columna cuando auditAccountTypeReady sea verdadero, o mapeo condicional) y eliminar el listener. Añadir una prueba que falle si un login emite algún UPDATE/DELETE sobre Auditoria. |

GL-03 Media Vulnerabilidad confirmada Abierto

### La cuenta de la aplicación tiene permisos amplios y puede modificar o borrar la auditoría

| | |
|---|---|
| Descripción | El esquema de referencia crea glucolume_app como miembro de db_datareader y db_datawriter y no define DENY sobre ninguna tabla. Además, el código contiene tres puntos legítimos de escritura destructiva sobre la auditoría (anulación de idUsuario al purgar cuentas no verificadas y depuración por retención), que deben resolverse antes de poder denegar UPDATE/DELETE. |
| Evidencia | `database/reference/GlucoLume_DB_v5.sql:4-8 (CREATE USER y ALTER ROLE; sin DENY/GRANT por objeto) · backend/app/services/unverifiedAccounts.py:104 (UPDATE) · backend/app/services/auditRetention.py:49 (DELETE de Audit) y :60 (UPDATE de AuditContext). Los permisos efectivos en la base real [NO VERIF.] no se consultaron.` |
| Impacto | **Alto.** Pérdida de integridad y no repudio del registro de auditoría ante un fallo de inyección, un error de código o una credencial filtrada. |
| Probabilidad | **Baja.** Baja: exige comprometer la aplicación o su credencial; la aplicación no ofrece ruta para editar eventos. |
| Severidad | Media (impacto alto × probabilidad baja) · Marcos: A01 · A09 · A.8.2 · A.8.15 · PR.AA-05 |
| Recomendación | Crear un rol/credencial separado para el servicio lifecycle (retención) y aplicar DENY UPDATE, DELETE sobre Auditoria y AuditoriaContexto a la cuenta de la API. Sustituir la anulación de idUsuario por un procedimiento ejecutado con el rol privilegiado o conservar la referencia pseudonimizada. Reemplazar db_datareader/db_datawriter por permisos por objeto. Orden: corregir GL-02, aplicar/validar 034, crear el rol de retención y recién entonces el DENY. |

GL-04 Media Vulnerabilidad confirmada Abierto

### El envío de correo usa STARTTLS sin verificar el certificado del servidor SMTP

| | |
|---|---|
| Descripción | El remitente llama a server.starttls() sin contexto SSL. En smtplib, sin contexto se usa ssl._create_stdlib_context(), que no verifica certificado ni nombre de host. La conexión se cifra, pero un intermediario activo en la ruta backend→SMTP podría presentar un certificado falso y capturar la credencial SMTP y el contenido de los correos (verificación de cuenta, recuperación, resultados de medición). |
| Evidencia | `backend/app/integrations/email/sender.py:36-38 (smtplib.SMTP + starttls() + login) · backend/app/core/config.py:70-74 (SMTP con STARTTLS, puerto 587). Prueba [PRUEBA] con el intérprete local Python 3.14.0: ssl._create_stdlib_context() devuelve verify_mode=0 (CERT_NONE) y check_hostname=False; el código fuente de SMTP.starttls usa ese contexto cuando context es None.` |
| Impacto | **Alto.** Exposición de la credencial SMTP y de resultados de salud en tránsito, y suplantación de correos del sistema. |
| Probabilidad | **Baja.** Baja: requiere posición de intermediario activo entre el servidor y el proveedor de correo. |
| Severidad | Media (impacto alto × probabilidad baja) · Marcos: A02 · A07 · A.8.24 · PR.DS-02 |
| Recomendación | Pasar context=ssl.create_default_context() a starttls() (y exigir TLS 1.2+). Añadir una prueba que verifique que el contexto usado valida certificados. |

GL-05 **Media** Riesgo pendiente de validación — Abierto

### El script 034 no está en la carpeta, pero el esquema v5 ya contiene su columna: estado real de la base sin determinar

| | |
|---|---|
| **Descripción** | El encargo y los comentarios del código describen 034 como borrador no aplicado y database/ solo contiene reference/, sin scripts/. Sin embargo, el esquema de referencia v5, generado el 19/10/2026 a las 00:45:03, ya incluye Auditoria.tipoCuentaActor y su CHECK. O bien v5 se generó desde una base que ya tiene la columna (034 aplicado o equivalente, sin registro de quién ni cuándo), o bien v5 se editó para anticipar el cambio. En el primer caso, GL-02 ya está activo en la base real. No hay tabla de migraciones que lo resuelva. Además, no pudo revisarse el contenido del script (ver sección 6.2). |
| **Evidencia** | `database/reference/GlucoLume_DB_v5.sql:3 (fecha de generación) · :32 (columna) · :1316-1318 (CHECK CK_Auditoria_tipoCuentaActor) · backend/app/models/audit.py:34-39,45-49 («borrador, no aplicado») · ausencia de database/scripts/034_auditoria_tipo_cuenta_actor.sql (backend/tests/test_auth_access_account_type.py:163 lo busca y no lo encuentra). Base real: [NO VERIF.]; no hay copia descartable disponible.` |
| **Impacto** | **Medio.** Cambio de esquema sin trazabilidad y desconocimiento de si la escritura de auditoría ya emite UPDATE en producción; imposibilidad de revisar y ensayar el script. |
| **Probabilidad** | **Media.** Media: la contradicción entre documentación y artefacto es verificable hoy. |
| **Severidad** | **Media** (impacto medio × probabilidad media) · Marcos: A04 · A05 · A.8.32 · PR.PS-01 |
| **Recomendación** | Consultar (solo lectura, por el responsable de la base) si existe la columna; restaurar el script 034 en database/scripts/ y ensayarlo en una copia descartable; registrar cada script aplicado (fecha y responsable) en una tabla de migraciones o en un registro versionado; alinear el comentario del modelo con la realidad. |

GL-06 **Media** Riesgo pendiente de validación — Abierto

### MFA_ENCRYPTION_KEY está definida dos veces con valores distintos

| | |
|---|---|
| **Descripción** | El .env define la clave dos veces con valores diferentes (comparación por hash; no se reproducen valores). Tanto pydantic-settings como Docker Compose toman la última aparición, de modo que la clave efectiva es la de la línea 52. Si los secretos TOTP ya guardados se cifraron con la otra, el descifrado fallaría y los usuarios con MFA (incluida la administración de la plataforma) quedarían sin poder completar el segundo factor. |
| **Evidencia** | `.env:42 y .env:52 (valores distintos, 44 caracteres cada uno) · backend/app/core/security.py:256-260 (una sola clave Fernet) · backend/app/core/config.py:52.` |
| **Impacto** | **Alto.** Pérdida de acceso MFA si la clave efectiva no es la que cifró los datos (no se comprobó: requeriría descifrar datos de la base real). |
| **Probabilidad** | **Baja.** Baja a media. |
| **Severidad** | **Media** (impacto alto × probabilidad baja) · Marcos: A02 · A05 · A.8.9 · A.8.24 · PR.DS-01 |
| **Recomendación** | Determinar, sin exponer las claves, cuál descifra los factores existentes (prueba controlada), eliminar la línea sobrante y respaldar la clave definitiva fuera del repositorio. Añadir al arranque una comprobación de claves duplicadas o inválidas. |

GL-07 **Media** Riesgo pendiente de validación — Abierto

### Cifrado en reposo, TLS verificado hacia la base y respaldos: sin evidencia en la carpeta

| | |
|---|---|
| **Descripción** | No hay evidencia de TDE en datos personales y de salud, de una política de respaldos cifrados con retención ni de una restauración de prueba (no existen docs/ en la carpeta; el README remite a un docs/DOCKER.md inexistente). La confianza ciega en el certificado de SQL Server queda limitada a development, y el .env actual corresponde a ese modo (API_ENV=development). |
| **Evidencia** | `backend/app/core/config.py:145-147 · .env:5 · README.md (sección Base de datos y Docker) · docker/mssql/Dockerfile:4 · compose.yaml:190 (la base no publica puertos). Estado real de la base, TLS y respaldos: [NO VERIF.].` |
| **Impacto** | **Alto.** Exposición de datos personales y de salud ante robo de disco o respaldo, o interceptación en tránsito hacia la base. |
| **Probabilidad** | **Baja.** Baja en un entorno académico local; sube si se publica. |
| **Severidad** | **Media** (impacto alto × probabilidad baja) · Marcos: A02 · A05 · A.8.13 · A.8.24 · PR.DS-01 / PR.DS-11 |
| **Recomendación** | Antes de publicar: TLS verificado con certificado válido, TDE, respaldos cifrados con retención y una restauración de prueba documentada; confirmar que el puerto 1433 no es accesible desde Internet. |

GL-08 **Media** Riesgo pendiente de validación — Abierto

### Resultados de salud por correo: consentimiento autodeclarado y correo del paciente guardado en claro

| | |
|---|---|
| **Descripción** | Para pacientes institucionales, el operador carga el correo y marca que el paciente autorizó; no hay verificación de que el destinatario sea quien dice (por ejemplo, enlace de confirmación). El correo se conserva 12 meses en PerfilMedicion en texto plano y los resultados (SpO2, frecuencia, glucosa experimental) viajan por SMTP. Hay mitigaciones: el correo no se conserva en el registro de envío, la auditoría no registra correos, hay un límite de 3 envíos por medición y hora y la interfaz lo enmascara. A esto se suma GL-04. |
| **Evidencia** | `backend/app/services/measurement.py:995 (límite), :1019 (casilla pacienteAutoriza), :1022 y :1079 (envío automático) · backend/app/services/resultEmailStore.py:3-7 (almacenamiento y 12 meses) · database/reference/GlucoLume_DB_v5.sql:503-505 (columnas correoResultados y fechas). Pruebas [PRUEBA]: test_result_email, test_result_email_on_save y test_patient_result_email pasan.` |
| **Impacto** | **Alto.** Divulgación de datos de salud a un tercero por error de tipeo o abuso de un operador; datos personales (correo) expuestos ante una filtración de la base. |
| **Probabilidad** | **Baja.** Baja: requiere un error u abuso de un operador autorizado. |
| **Severidad** | **Media** (impacto alto × probabilidad baja) · Marcos: A04 · A02 · Ley 25.326 · A.5.34 · PR.DS-01 |
| **Recomendación** | Confirmación del destinatario por enlace antes del primer envío; cifrar la columna (por ejemplo con la misma infraestructura Fernet) o limitar su uso; exigir TLS verificado (GL-04); documentar la base legal del tratamiento; límite por operador y por destinatario. |

GL-09 Baja Vulnerabilidad confirmada — Abierto

### La carpeta es incompleta y no reproducible: faltan documentación, scripts SQL y control de versiones

| | |
|---|---|
| Descripción | El README referencia docs/, database/scripts/, database/herramientas/ y un esquema v3 que no existen en la carpeta (hay v5). Tres pruebas del backend leen scripts SQL que faltan (028, 033 y 034); solo la de 034 estaba en el alcance ejecutado. No hay repositorio Git: no existe historial ni integridad de cambios, y no está la auditoría previa que el encargo cita como línea base. |
| Evidencia | `README.md (enlaces a docs/DOCKER.md, docs/SEGURIDAD_IMAGENES.md, database/scripts, database/herramientas, GlucoLume_DB_v3.sql) · ausencia verificada de esos archivos y de .git · backend/tests/test_auth_access_account_type.py:163, test_platform_institution_deletion.py:254, test_quota.py:74. Prueba [PRUEBA]: test_el_script_034_… falla con FileNotFoundError.` |
| Impacto | **Bajo.** No se puede reproducir una instalación ni trazar cambios; la suite no pasa íntegra; el jurado o un tercero no puede contrastar hallazgos previos. |
| Probabilidad | **Alta.** Ocurre hoy. |
| Severidad | Baja (impacto bajo × probabilidad alta) · Marcos: A05 · A08 · A.5.37 · A.8.32 · GV.PO |
| Recomendación | Restaurar los directorios y scripts faltantes (o corregir el README y las pruebas), versionar la carpeta con Git y conservar las auditorías en docs/seguridad/auditorias/. |

GL-10 Baja Vulnerabilidad confirmada — Abierto

### DATABASE_URL huérfano en el .env duplica la contraseña de la base

| | |
|---|---|
| Descripción | El .env define DATABASE_URL (137 caracteres, que incluye la contraseña de la base) y nada en el backend, Docker o Compose la lee: duplica un secreto sin función. |
| Evidencia | `.env:16 · búsqueda de DATABASE_URL en backend/app, docker/ y compose*.yaml: sin coincidencias · ausente de .env.example.` |
| Impacto | **Bajo.** Un secreto duplicado en un archivo local. |
| Probabilidad | **Baja.** Baja. |
| Severidad | Baja (impacto bajo × probabilidad baja) · Marcos: A05 · A.8.9 |
| Recomendación | Eliminar la línea (acción del propietario del .env). |

GL-11 Baja Mejora preventiva — Abierto

### Endpoints del puente sin límite por IP y token único compartido sin rotación

| | |
|---|---|
| Descripción | El puente se autentica con un token estático compartido (64 caracteres, comparación en tiempo constante). No hay token por puente, rotación ni revocación individual, y los endpoints /bridge/ingest y /bridge/check no figuran entre los límites por IP. |
| Evidencia | `backend/app/api/v1/telemetry.py:48-54 · backend/app/api/rateLimit.py:23-38 (lista LIMITS sin puente) · docker/nginx/default.conf.template:85-87 (limit_req solo en /api/v1/auth/).` |
| Impacto | **Medio.** Quien obtenga el token puede inyectar lecturas al dispositivo que elija. |
| Probabilidad | **Baja.** Baja. |
| Severidad | Baja (impacto medio × probabilidad baja) · Marcos: A07 · A04 · A.8.5 · PR.AA |
| Recomendación | Token por puente o dispositivo con rotación, límite por IP en los endpoints del puente y auditoría de fallos de token. |

GL-12 Baja Mejora preventiva — Abierto

### La suite de pruebas depende del .env real

| | |
|---|---|
| Descripción | Las pruebas cargan la configuración desde el .env del desarrollador, por lo que su resultado depende del entorno. Es útil para detectar GL-01, pero hace las pruebas no reproducibles. |
| Evidencia | `Prueba [PRUEBA]: 3 fallos con el .env real que desaparecen con ALLOW_INDIVIDUAL_ON_INSTITUTIONAL_DEVICE=false en el entorno del proceso (ver GL-01).` |
| Impacto | **Bajo.** Resultados no reproducibles entre equipos. |
| Probabilidad | **Alta.** Ocurre hoy. |
| Severidad | Baja (impacto bajo × probabilidad alta) · Marcos: A05 · A.8.29 · PR.PS-01 |
| Recomendación | Fijar en conftest.py los valores de seguridad relevantes y mantener pruebas específicas para ambos valores del interruptor. |

GL-13 Baja Riesgo pendiente de validación — Abierto

### Dependencias e imágenes sin reescaneo en esta revisión; imágenes fijadas por etiqueta

| | |
|---|---|
| Descripción | Las dependencias de Python se instalan con --require-hashes y el frontend tiene package-lock.json (controles positivos), pero no se ejecutó pip-audit, npm audit ni escaneo de imágenes (consultan bases externas) y no existe la nota de vulnerabilidades referenciada por el README. Las imágenes base se fijan por etiqueta, no por digest. frontend/node_modules no está presente. |
| Evidencia | `backend/Dockerfile:14,21,24 · frontend/Dockerfile:20 (npm ci) · docker/mssql/Dockerfile:4 · compose.prod.yaml (caddy:2.9-alpine) · frontend/package.json (react 19.1.0, vite 6.4.4, react-router-dom 7.18.4).` |
| Impacto | **Medio.** Vulnerabilidades conocidas no detectadas. |
| Probabilidad | **Baja.** Baja. |
| Severidad | Baja (impacto medio × probabilidad baja) · Marcos: A06 · A08 · A.8.8 · ID.RA-01 |
| Recomendación | Repetir pip-audit, npm audit y un escaneo de imágenes el día del despliegue; fijar imágenes por digest. |

GL-14 Baja Riesgo pendiente de validación — Riesgo aceptado

### Refresh token en localStorage con «Recordarme»

| | |
|---|---|
| Descripción | Con «Recordarme» el refresh token persiste en localStorage, expuesto a robo si existiera un XSS. La búsqueda de hoy no encontró usos peligrosos de HTML y la CSP restringe scripts; el refresh se rota en cada uso con detección de reutilización. |
| Evidencia | `frontend/src/auth/tokenStore.js:6-7,31,36 · backend/app/services/auth.py:913-930 · docker/nginx/default.conf.template:50.` |
| Impacto | **Medio.** Toma de sesión ante un XSS futuro. |
| Probabilidad | **Baja.** Baja. |
| Severidad | Baja (impacto medio × probabilidad baja) · Marcos: A07 · A.8.5 · PR.AA-03 |
| Recomendación | Mantener la aceptación y evaluar a futuro refresh en cookie HttpOnly + SameSite con protección CSRF. |

GL-15 Baja Mejora preventiva — Abierto

### Contadores y límites en memoria del proceso, sin CAPTCHA y con señales pasivas

| | |
|---|---|
| Descripción | Los límites por IP y los monitores viven en la memoria del proceso: válidos con una réplica, no con varias, y se reinician con el servicio. No hay CAPTCHA y las señales de actividad sospechosa no generan alertas activas. |
| Evidencia | `backend/app/api/rateLimit.py:23,42 (LIMITS y _limiters) · backend/app/services/securityMonitor.py.` |
| Impacto | **Bajo.** Ataques distribuidos o tras reinicios eluden los límites. |
| Probabilidad | **Media.** Media. |
| Severidad | Baja (impacto bajo × probabilidad media) · Marcos: A07 · A04 · A.8.16 · DE.CM-01 |
| Recomendación | Mantener una sola réplica o incorporar Redis; alertas por correo ante señales confirmadas; WAF delante de Nginx. |

GL-16 Baja Mejora preventiva — Abierto

### La auditoría se conserva sin límite por defecto

| | |
|---|---|
| Descripción | AUDIT_RETENTION_MONTHS=0 conserva todos los eventos indefinidamente porque el plazo legal no está aprobado. La IP y el cliente sí se anulan pasado AUDIT_CONTEXT_RETENTION_DAYS (90 por defecto). |
| Evidencia | `backend/app/core/config.py:114-117 · backend/app/services/auditRetention.py:1-12.` |
| Impacto | **Bajo.** Incumplimiento potencial de minimización. |
| Probabilidad | **Media.** Media. |
| Severidad | Baja (impacto bajo × probabilidad media) · Marcos: Privacidad (Ley 25.326) · A.5.34 · A09 |
| Recomendación | Aprobar con asesoría legal un plazo de conservación y configurarlo. |

GL-17 Baja Mejora preventiva — Abierto

### Clave de cifrado MFA única sin rotación; JWT_SECRET reutilizado como clave de HMAC

| | |
|---|---|
| Descripción | El cifrado de factores usa una única clave Fernet, sin mecanismo de rotación (MultiFernet). El HMAC de los códigos cortos usa JWT_SECRET directamente y el de los identificadores auditados lo deriva con separación de dominio; rotar JWT_SECRET invalida todos los tokens y cambia ambas huellas. |
| Evidencia | `backend/app/core/security.py:228-238,256-260 · backend/app/services/audit.py:200-205.` |
| Impacto | **Bajo.** Rotación operativa costosa. |
| Probabilidad | **Baja.** Baja. |
| Severidad | Baja (impacto bajo × probabilidad baja) · Marcos: A02 · A.8.24 · PR.DS-01 |
| Recomendación | Soportar varias claves de cifrado y derivar claves distintas por propósito desde una raíz. |

GL-18 Baja Mejora preventiva — Abierto

### Endurecimientos menores de configuración Docker

| | |
|---|---|
| Descripción | compose.yaml configura FORWARDED_ALLOW_IPS="*" para el backend: en desarrollo (backend publicado en 127.0.0.1:8000) un cliente local podría falsear la IP registrada en la auditoría; en producción el backend no se publica. La imagen de SQL Server no aplica cap_drop ni no-new-privileges (justificado en el archivo). |
| Evidencia | `compose.yaml:48 · compose.dev.yaml:14-15 · compose.yaml:177-179.` |
| Impacto | **Bajo.** Falsificación de IP en la auditoría en desarrollo. |
| Probabilidad | **Baja.** Baja. |
| Severidad | Baja (impacto bajo × probabilidad baja) · Marcos: A05 · A08 · A.8.9 |
| Recomendación | Limitar FORWARDED_ALLOW_IPS al CIDR de Nginx también en desarrollo. |

GL-19 Baja Mejora preventiva — Abierto

### CSP con style-src 'unsafe-inline'

| | |
|---|---|
| Descripción | La política de Nginx admite estilos en línea. Los scripts siguen restringidos a 'self' (script-src 'self'), de modo que no habilita ejecución de código, pero debilita la defensa en profundidad frente a inyección de estilos y exfiltración vía CSS. |
| Evidencia | `docker/nginx/default.conf.template:50 (y :133 para la documentación, que además permite cdn.jsdelivr.net).` |
| Impacto | **Bajo.** Menor resistencia a inyección de estilos. |
| Probabilidad | **Baja.** Baja. |
| Severidad | Baja (impacto bajo × probabilidad baja) · Marcos: A05 · A03 · A.8.20 · PR.PS |
| Recomendación | Separar style-src-elem 'self' de style-src-attr 'unsafe-inline' o usar hashes/nonces; confirmar que /docs no se expone en producción. |

GL-20 Baja Mejora preventiva — Abierto

### Secretos reales en texto plano en una carpeta sin repositorio

| | |
|---|---|
| Descripción | El .env y acquisition/bridge/bridge.env contienen secretos reales (JWT_SECRET, SESSION_SECRET, DB_PASSWORD, SMTP_PASSWORD, GOOGLE_CLIENT_SECRET, BRIDGE_TOKEN). Están excluidos por .gitignore y no hay patrones de claves en el código fuente, pero al no existir repositorio la exclusión no protege nada hoy (por ejemplo, ante un ZIP de la carpeta). El .gitignore repite las mismas reglas varias veces. |
| Evidencia | `.env y acquisition/bridge/bridge.env (nombres y longitudes inspeccionados, no valores) · .gitignore:11-13,17,26 · .env.example sin valores · búsqueda de patrones de claves en el código: sin coincidencias.` |
| Impacto | **Medio.** Compromiso de credenciales si la carpeta se comparte o copia. |
| Probabilidad | **Baja.** Baja. |
| Severidad | Baja (impacto medio × probabilidad baja) · Marcos: A02 · A05 · A.5.17 · A.8.24 |
| Recomendación | No compartir la carpeta con los .env; rotar JWT_SECRET, SESSION_SECRET, BRIDGE_TOKEN y las credenciales de base y SMTP antes de cualquier publicación; limpiar el .gitignore. |

GL-21 Baja Mejora preventiva — Abierto

### BorrarRap.sql (borrado masivo) convive con el esquema de referencia sin controles de entorno

| | |
|---|---|
| Descripción | El script deshabilita claves foráneas y ejecuta DELETE FROM sobre todas las tablas. Su única salvaguarda es abortar si existen tablas temporales; no verifica el nombre de la base ni el entorno, y está en database/reference junto al esquema que se usa para instalar. |
| Evidencia | `database/reference/BorrarRap.sql:15-25 (única guarda) y :71 (DELETE FROM dinámico).` |
| Impacto | **Bajo.** Pérdida accidental de datos si se ejecuta en la base equivocada. |
| Probabilidad | **Baja.** Baja. |
| Severidad | Baja (impacto bajo × probabilidad baja) · Marcos: A04 · A05 · A.8.31 |
| Recomendación | Moverlo a una carpeta de herramientas con aviso, exigir confirmación explícita (variable o nombre de base esperado) y no ejecutarlo con la cuenta de la aplicación. |

# 7. Matriz de riesgos

Cada hallazgo se ubica por impacto (filas) y probabilidad (columnas). La severidad resulta de la combinación según la regla de la sección 3.2.

| | Probabilidad Baja | Probabilidad Media | Probabilidad Alta |
|---|---|---|---|
| **Impacto Alto** | GL-03<br>GL-04<br>GL-06<br>GL-07<br>GL-08 | GL-01 | – |
| **Impacto Medio** | GL-11<br>GL-13<br>GL-14<br>GL-20 | GL-02<br>GL-05 | – |
| **Impacto Bajo** | GL-10<br>GL-17<br>GL-18<br>GL-19<br>GL-21 | GL-15<br>GL-16 | GL-09<br>GL-12 |

Rojo = Alta, ámbar = Media, verde = Baja. El color acompaña al texto de severidad de cada ficha; no es la única señal.

## 7.1 Riesgo residual global

El riesgo residual se concentra en cuatro líneas: (1) configuración que puede anular controles de autorización o de secreto (GL-01, GL-06); (2) integridad y confidencialidad en la capa de base de datos, que depende de infraestructura no inspeccionada (GL-03, GL-05, GL-07); (3) confidencialidad de los datos de salud en tránsito y en correo (GL-04, GL-08); y (4) reproducibilidad y trazabilidad de la propia entrega (GL-09). Con el interruptor de GL-01 desactivado, no se encontró en esta revisión una vía que permita leer datos de salud ajenos o tomar cuentas.

## 8. Comparación con la auditoría anterior

> **Línea base no disponible.** El encargo cita una auditoría del 17/10/2026 como línea base. La carpeta `GlucoLume` no contiene directorio `docs/` ni ningún informe de auditoría, y por instrucción no se utilizó otra carpeta. Por lo tanto **no se declara el estado (corregido, abierto o regresado) de los hallazgos anteriores** y esta revisión funciona como auditoría inicial completa dentro de la carpeta.

Lo que sí puede contrastarse con elementos presentes en la carpeta:

| Elemento | Contraste con evidencia local |
|---|---|
| Verificación del esquema (README) | El README afirma una verificación del 17/10/2026 del esquema v3 en una base descartable y remite a `GlucoLume_DB_v3.sql`; esa verificación no es contrastable [DOC] y la carpeta contiene v5 (generado el 19/10/2026), no v3 (GL-09). |
| Control de autoridad sobre el puente | El código y sus pruebas expresan la intención de que las cuentas individuales y los operadores de otras instituciones no den órdenes al puente de una institución. Esa intención **no se cumple con la configuración actual** (GL-01): regresión de configuración detectada por las pruebas existentes. |
| Script 034 «borrador no aplicado» | Afirmación de comentarios y del encargo contradicha por el esquema v5 (GL-05). |
| Resto de controles | Se verificaron de forma independiente en esta revisión (secciones 5 y 10); su comparación con informes previos queda pendiente hasta contar con ellos. |

**Recomendación:** incorporar los informes previos a `docs/seguridad/auditorias/` y, una vez disponibles, completar esta sección con una tabla de estado hallazgo por hallazgo. Los hallazgos de este informe están numerados GL-01 a GL-21 y pueden referenciarse en futuras revisiones.

## 9. Recomendaciones priorizadas

| Prior. | Acción | Hallazgos | Momento |
|---|---|---|---|
| **P0** | Desactivar ALLOW_INDIVIDUAL_ON_INSTITUTIONAL_DEVICE en el .env y en compose.prod.yaml, y hacer que Settings rechace el arranque en producción con el interruptor activo. | GL-01 | Inmediato; antes de cualquier despliegue |
| **P0** | Resolver la duplicidad de MFA_ENCRYPTION_KEY con una prueba de descifrado controlada y respaldar la clave definitiva fuera de la carpeta. | GL-06 | Antes de usar MFA con datos reales |
| **P0** | Verificar el certificado en STARTTLS (ssl.create_default_context()). | GL-04 | Antes de enviar correos con datos reales |
| **P1** | Consultar (solo lectura) si la base real ya tiene tipoCuentaActor; restaurar el script 034 en database/scripts/, ensayarlo en una copia descartable y registrar cada script aplicado. | GL-05, GL-09 | Antes de aplicar 034 o cualquier migración |
| **P1** | Escribir tipoCuentaActor en el INSERT y eliminar el listener con UPDATE; luego crear el rol de retención y aplicar DENY UPDATE, DELETE sobre Auditoria y AuditoriaContexto a la cuenta de la API; permisos por objeto. | GL-02, GL-03 | Antes de producción (en ese orden) |
| **P1** | TLS verificado hacia la base, TDE, respaldos cifrados con retención y restauración de prueba documentada. | GL-07 | Antes de producción con datos reales |
| **P1** | Confirmación del destinatario por enlace antes del primer envío de resultados; cifrar o limitar el correo guardado; documentar base legal. | GL-08 | Antes de usar pacientes reales |
| **P1** | Rotar JWT_SECRET, SESSION_SECRET, BRIDGE_TOKEN y credenciales de base y SMTP antes de publicar; no compartir la carpeta con los .env. | GL-20 | Antes de publicar |
| **P2** | Restaurar docs/ y database/scripts/, versionar con Git y conservar auditorías en docs/seguridad/auditorias/; eliminar DATABASE_URL; aislar la suite del .env real. | GL-09, GL-10, GL-12 | Próxima iteración |
| **P2** | Repetir pip-audit, npm audit y escaneo de imágenes; fijar digests. Token por puente con rotación y límite por IP. | GL-11, GL-13 | Día del despliegue / próxima iteración |
| **P3** | Plazo de retención aprobado, alertas activas, varias claves de cifrado, Redis si se escala, CSP sin 'unsafe-inline', FORWARDED_ALLOW_IPS acotado, controles en BorrarRap.sql. | GL-14 a GL-19, GL-21 | Planificado |

> **Orden recomendado para los cambios en la base:** (1) corregir el código de GL-02, (2) ensayar el script en una copia descartable y registrar el cambio, (3) crear el rol de retención, (4) recién entonces aplicar el DENY. Invertir (2) y (4) dejaría el inicio de sesión dependiente de un UPDATE denegado.

P0 = inmediato · P1 = antes de producción con datos reales · P2 = próxima iteración · P3 = planificado. Esta auditoría no aplicó ninguna corrección.

# 10. Pruebas realizadas, no ejecutadas y limitaciones

## 10.1 Pruebas realizadas

| Prueba | Resultado | Notas |
|---|---|---|
| Lote dirigido de 21 módulos del backend: test_security_hardening, test_auth_access_account_type, test_audit_security, test_audit_names, test_audit_minimized_names, test_rate_limiter, test_login_lockout, test_mfa_attempts_atomic, test_device_context_authority, test_bridge_command_authority, test_telemetry, test_device_resolve_authority, test_patient_access, test_dashboard_privacy, test_stream_limits, test_manager_reassignment, test_platform_recovery, test_result_email, test_result_email_on_save, test_patient_result_email, test_retention_anonymization | **317 aprobadas, 4 fallidas** (174 s) | Cubren autenticación, bloqueo, MFA, límites, auditoría, aislamiento, privacidad, puente, streams, retención y resultados por correo. SQLite temporal con el esquema de los modelos. |
| Diferenciación de fallos (3 de los 4) | Reproducidos: pasan con la variable en false | **Fallos de configuración, no de código** (GL-01): test_bridge_command_authority::...ajena_no_puede_ordenar..., test_device_context_authority::...sigue_bloqueado..., test_telemetry::... otra_institucion_no_se_puede_usar. Al ejecutarlas con ALLOW_INDIVIDUAL_ON_INSTITUTIONAL_DEVICE=false en el entorno del proceso: 3 aprobadas. |
| Cuarto fallo | FileNotFoundError | **Preexistente y de entorno**: test_el_script_034_... lee database/scripts/034_...sql, que no existe en la carpeta (GL-09). |
| Prueba de concepto de GL-02 | Reproducida | Un loginLocal exitoso emite un UPDATE sobre Auditoria (SQLite temporal, captura de SQL con before_cursor_execute). Script en el directorio temporal de la sesión, fuera del proyecto. |
| Prueba de GL-04 | Confirmada | Inspección del código de smtplib.SMTP.starttls y ssl._create_stdlib_context() en Python 3.14.0 local: verify_mode=0, check_hostname=False. No se hizo ninguna conexión SMTP. |
| Comparación de claves duplicadas (GL-06) | Distintas | Comparación por hash de las dos líneas MFA_ENCRYPTION_KEY; no se mostraron valores. |
| Búsquedas estáticas dirigidas | Sin hallazgos | SQL dinámico (f-strings en text/execute), dangerouslySetInnerHTML/innerHTML/eval/document.write/insertAdjacentHTML, patrones de claves privadas y tokens en el código. Lectura de config, JWT, sesiones, MFA, OAuth, rate limit, auditoría, Nginx, Caddy, Compose, Dockerfiles y esquema SQL. |
| Revisión del esquema v5 y de BorrarRap.sql | Realizada | Búsqueda de GRANT/DENY/roles, tablas de auditoría y columnas de las migraciones 030, 033 y 034; sin ejecutar nada. |
| Comprobación de copia descartable de SQL Server | No disponible | Solo lectura de nombres de bases de la instancia local: únicamente existe la base GlucoLume. No se consultó su contenido. |

### 10.2 Pruebas no ejecutadas

- Suite completa del backend (1 813 pruebas recolectadas) y del frontend: sin justificación técnica para repetirla; se ejecutaron los módulos afectados por los riesgos identificados. Las pruebas del frontend no pudieron ejecutarse: la carpeta no contiene `frontend/node_modules` y instalarlas consulta la red.
- Pruebas contra SQL Server (`*_sqlserver`, concurrencia) y ejecución de cualquier script SQL: no hay copia descartable.
- pip-audit, npm audit y escaneo de imágenes (consultan bases externas); ejecución de Nginx, Caddy y Docker de esta carpeta (ningún contenedor suyo estaba en ejecución).
- Pruebas con Google real, SMTP real, carga, denegación de servicio o ataques activos.
- Consulta de permisos efectivos, TLS, TDE y respaldos de la base real.

### 10.3 Limitaciones

- La carpeta no tiene repositorio Git: no se evaluó historial ni se diferenciaron «cambios recientes» por control de versiones; solo por fechas de archivo y comentarios del código.
- La auditoría previa y la documentación (`docs/`) no están en la carpeta; no hay comparación hallazgo por hallazgo (sección 8).
- Las pruebas usan SQLite con el esquema de los modelos: no demuestran el comportamiento de T-SQL, bloqueos ni permisos de SQL Server.
- Que las pruebas pasen demuestra que los comportamientos probados se cumplen, no que el sistema esté libre de vulnerabilidades.
- La ejecución de pytest genera archivos `__pycache__` dentro del proyecto (no son código ni configuración).
- La imagen de seguridad corresponde a una revisión puntual de un proyecto que cambia con rapidez.

## 11. Seguridad del software frente a validación clínica del dispositivo

Este informe evalúa exclusivamente la **seguridad del software** de GlucoLume. No evalúa si el dispositivo mide correctamente.

**Lo que este informe evalúa**

- Quién puede acceder a qué dato y con qué trazabilidad.
- Si los datos almacenados y transmitidos están protegidos contra acceso o alteración no autorizados.
- Si el software conserva la integridad de lo que recibe (validación de entradas, autoría, historial).
- Si el sistema resiste abuso (fuerza bruta, inundación, enumeración).

**Lo que NO evalúa**

- Si las estimaciones de SpO2, frecuencia cardíaca o glucosa son correctas, exactas o clínicamente útiles.
- La calibración del sensor óptico, el firmware como dispositivo médico, la seguridad eléctrica o la biocompatibilidad.
- La validez de los algoritmos de procesamiento respecto de una referencia clínica.
- El cumplimiento de la normativa de productos médicos ni la aprobación de un comité de ética.

> GlucoLume se presenta como plataforma experimental. Un sistema seguro desde el punto de vista informático puede registrar y proteger con fidelidad mediciones que son clínicamente incorrectas. Que el software proteja la integridad de un dato no demuestra que el dato mida lo que dice medir. Ninguna conclusión de este informe debe usarse como evidencia de exactitud diagnóstica, y los resultados no deben emplearse para decisiones de tratamiento.

La validación clínica requiere un diseño experimental propio (población, referencia, error medio, concordancia, aprobación ética) y, si el dispositivo se destinara a uso médico, un proceso regulatorio. Se recomienda que la memoria del trabajo de titulación mantenga estas dos dimensiones separadas.

# 12. Dictamen

> **Dictamen: CONDICIONADO para despliegue.**

| Escenario | Dictamen |
|---|---|
| Demostración académica en entorno controlado, datos sintéticos, instalación local | **Apto**, con el interruptor GL-01 desactivado si participan cuentas de distintas instituciones. |
| Publicación o uso con datos reales de personas | **No apto** hasta cumplir las condiciones siguientes. |

## Condiciones para pasar a «apto»

1. Cerrar GL-01, GL-04 y GL-06 (P0).
2. Determinar el estado real de 034, corregir la escritura de tipoCuentaActor (GL-02) y aplicar el endurecimiento de la auditoría en el orden indicado (GL-03, GL-05).
3. Verificar y documentar TLS hacia la base, TDE y respaldos con una restauración de prueba (GL-07).
4. Resolver la verificación del destinatario y la protección del correo del paciente (GL-08).
5. Rotar los secretos de desarrollo y repetir los escaneos de dependencias e imágenes el día del despliegue (GL-13, GL-20).
6. Restaurar la documentación y los scripts de la carpeta, versionarla y conservar este informe como línea base (GL-09).
7. Aprobar la política de retención con asesoría legal (GL-16).

Este dictamen se sustenta en la evidencia de la sección 10 y no declara que la aplicación esté «completamente segura»: la auditoría no inspeccionó la base real, el servidor de producción ni la consola de Google, y no sustituye una prueba de penetración externa. Tampoco constituye una validación clínica del dispositivo.

Informe generado el 19/10/2026. No se modificó código, configuración, secretos, Docker ni bases de datos; no se aplicaron migraciones.